



Elaborado por:

Revisores:

Roberto Daniel Saavedra Caballero		Roberto Daniel Saavedra Caballero	

Roberto Daniel Saavedra Caballero



índice

DICTAMEN.....	3
Situaciones relevantes	4
Situaciones auditadas.....	5
Programa de trabajo	6
Guía de auditoría	8
Inventario software	9
Inventario hardware.....	10
Inventario de consumibles	11
Manual de organización.....	12
Descripción de puestos.....	13
Reporte de pruebas	15
Pruebas sistema y software	16
Backup y reportes	17
Guía señales y marcas.....	18
Cuestionarios y entrevistas.....	19
Anexos, cuadros y estadísticas	20



DICTAMEN

AUDITORÍA EN SISTEMAS COMPUTACIONALES

Santiago Tianguistenco a 12 de Diciembre de 2023

Roberto Daniel Saavedra Caballero

Integrante del equipo de diseño

Presente:

De acuerdo con las instrucciones indicadas en clase, se llevará a cabo una auditoría en sistemas computacionales el día 12 de enero de 2024 al equipo haciendo énfasis en los servidores, bases de datos, funcionamiento y operación de la página web correspondiente. El objetivo de la auditoría es evaluar la seguridad y el cumplimiento de políticas en los sistemas antes mencionados.

Los objetivos específicos de la auditoría son:

- Revisar que los servidores, estaciones de trabajo y equipos de red cumplan con las políticas y estándares de seguridad establecidos.
- Revisar la documentación correspondiente a cada funcionalidad de la página web.
- Verificar que se hayan aplicado las actualizaciones y parches de seguridad correspondientes.
- Comprobar que existan controles de acceso físico y lógico adecuados.
- Examinar las configuraciones de los equipos.
- Revisar los registros y monitoreo de actividades del sistema.

Para cumplir con los objetivos, se realizarán los siguientes procedimientos:

- Revisión de políticas, estándares y métricas establecidas en la documentación.
- Inspección de registros de actualizaciones y cambios a los sistemas.
- Evaluación de vulnerabilidades técnicas.
- Entrevistas con personal administrativo y técnico.
- Análisis de configuraciones y registros de actividad.

Atentamente

Roberto Daniel Saavedra Caballero

Situaciones relevantes

Se detectó que el formulario de contacto es vulnerable a inyección SQL y permite obtener información confidencial del servidor. Específicamente, en la variable "nombre" se puede ingresar código malicioso debido a que no se valida ni sanitiza la entrada antes de construir la consulta SQL.

También se identificó que el certificado SSL utilizado en el sitio web está caducado desde hace 6 meses, lo cual pone en riesgo la seguridad en transacciones y envío de información delicada de los usuarios. El proveedor había notificado del vencimiento, pero no se tomó acción debido a falta de presupuesto para la renovación.

Situaciones auditadas

Situación 1: Formulario contacto vulnerable

Causa Raíz: Falta de codificación segura en la validación y procesamiento de variables provenientes de entrada de usuario. No se utilizan consultas parametrizadas.

Solución sugerida: Implementar validación de entradas en el lado del servidor antes de construir consultas SQL. Utilizar consultas parametrizadas.

Situación 2: Certificado SSL caducado

Causa Raíz: Falta de presupuesto reservado para renovación periódica del certificado SSL. No existen procesos establecidos para gestionar el ciclo de vida de los certificados.

Solución Sugerida: Establecer proceso formal para gestión de certificados digitales. Renovar de inmediato el SSL vigente con proveedor X. Solicitar presupuesto de contingencia para renovaciones futuras.

Programa de trabajo

I. Información General de la Página Web:

Nombre de la Página Web:

URL:

Propósito de la Página:

Fecha de Inicio de la Auditoría:

Fecha de Finalización de la Auditoría:

II. Auditoría de Seguridad:

A. Revisión de Seguridad:

1. Escaneo de Vulnerabilidades.
2. Revisión de Políticas de Seguridad.
3. Análisis de Certificados SSL.

B. Autenticación y Autorización:

1. Evaluación de Métodos de Autenticación.
2. Revisión de Controles de Acceso.

III. Auditoría de Rendimiento:

A. Velocidad de la Página:

1. Evaluación del Tiempo de Carga.
2. Análisis de Elementos que afectan la Velocidad.

B. Optimización de Imágenes:

1. Evaluación de Tamaño y Compresión de Imágenes.
2. Implementación de Lazy Loading.

C. Pruebas de Rendimiento:

1. Uso de Herramientas como Google PageSpeed Insights o similares.
2. Evaluación del Rendimiento en Diferentes Navegadores.

IV. Auditoría de Contenido:

A. Precisión y Actualización:

1. Revisión de Contenido para Precisión.
2. Actualización de Información Relevante.

B. Enlaces y Navegación:

1. Verificación de Enlaces Rotos.
2. Evaluación de la Estructura de Navegación.

C. Cumplimiento de Normativas:

1. Revisión de Conformidad con Leyes y Regulaciones GDPR.

V. Auditoría de Usabilidad:

A. Experiencia del Usuario:

1. Evaluación de la Facilidad de Uso.
2. Pruebas de Navegación Intuitiva.

VI. Informe Final:

Resumen de Hallazgos.

Recomendaciones para Mejoras.

Plan de Acción Propuesto.

Guía de auditoría

[illegible]

Inventario software

Sistema operativo: Windows 11

Servidor web: Apache 2.4

Lenguaje de programación: PHP 7.2

Gestor de base de datos: MySQL 8.1

Software ofimático: Microsoft Office 2019

Software de diseño gráfico: Visual Studio Code

Cliente de correo electrónico:

Software de auditoría: Visual Studio Code

Inventario hardware

Servidores:

- Servidor Base de datos: Laptop Victus HP, 16GB RAM, 11th Gen Intel(R) Core (TM) i7-11800H @ 2.30GHz 2.30 GHz.

Estaciones de trabajo:

- Diseñadores gráficos: iMac 27", 32GB RAM, 1TB SSD
- Desarrolladores: Laptop Dell Latitude, 16GB RAM, 500GB SSD
- Equipo gerencial: Laptop ThinkPad X1 Carbon, 16GB RAM, 1TB SSD

Periféricos:

- Impresoras
- Scanners de documentos

Mobiliario:

- Escritorios
- Sillas para oficina

Inventario de consumibles

Papelería:

- Hojas
- Lapiceros
- Marcadores
- Borradores
- Clips
- Folders AZ

Tóner para impresoras:

- Negro
- Color

Insumos tecnológicos:

- Cables de red
- Memorias USB
- Adaptadores
- Discos duros externos

Manual de organización

Organigrama:

- Líder de proyecto
- Diseño Gráfico (2 diseñadores)
- Desarrollo (1 líder técnico, 2 programadores)
- Operaciones (2 administradores de bases de datos)

Funciones:

- Líder de proyecto: Dirección estratégica, visión de negocio
- Diseño: Creación de interfaces y recursos gráficos
- Desarrollo: Codificación de aplicaciones y funcionalidades
- Operaciones: Gestión de bases de datos

Jerarquías:

- Nivel superior: Líder de proyecto
- Nivel medio: Líder de Desarrollo, Administrador de Operaciones
- Nivel operativo: Resto de áreas

Autoridades:

- Gerente General posee autoridad total sobre visión de producto y negocio.
- Líderes de área tienen autoridad sobre sus equipos.

Descripción de puestos

Desarrollador Backend:

Funciones:

- Codificación de funcionalidades del lado del servidor
- Diseño y optimización de bases de datos
- Integración de APIs y servicios externos
- Documentación técnica de arquitectura y código

Habilidades:

- Dominio de lenguajes como PHP, Python, Java
- Conocimiento de frameworks web como Laravel, Django
- Experiencia en gestores de bases de datos MySQL, PostgreSQL
- Capacidad de diseño de bases de datos relacionales
- Conocimiento de arquitectura de software, microservicios

Desarrollador Frontend:

Funciones:

- Desarrollo de interfaces de usuario modernas y adaptables
- Programación del lado del cliente con HTML, CSS, JavaScript
- Construcción de componentes reutilizables

Habilidades:

- Dominio de HTML5, CSS3, JavaScript ES6
- Experiencia en frameworks de JS como React o Angular
- Conocimientos de responsive design y SPA
- Experiencia en preprocesadores como SASS
- Conocimientos de gestores de paquetes y automatización

Diseñador Web

Funciones:

- Creación de diseño visual y experiencia de usuario (UX/UI)
- Desarrollo de wireframes y prototipos de alta fidelidad
- Diseño de interfaces visuales adaptables a diferentes dispositivos
- Creación de recursos gráficos como icons e imágenes
- Definición y documento de guías de estilo visual de productos

Habilidades:

- Dominio de herramientas como Figma, Sketch, Adobe CC
- Experiencia en diseño visual, de interacción y UI
- Conocimiento de principios de diseño, colores, tipografías
- Capacidad para traducir requerimientos en diseños efectivos y estéticamente agradables

Administrador de Base de Datos

Funciones:

- Instalación, configuración y mantenimiento de sistemas de bases de datos
- Monitoreo y performance tuning
- Definición y control de estándares de modelado de datos
- Respaldo y recuperación de bases de datos
- Aseguramiento de integridad, disponibilidad y confidencialidad de los datos

Habilidades:

- Experiencia en administración de MySQL, Oracle, SQL Server
- Conocimiento sólido de lenguaje SQL
- Experiencia en optimización de queries
- Habilidades para análisis de capacidad y monitoreo
- Conocimientos de replicación, clustering y continuity

Reporte de pruebas

Pruebas de seguridad en formulario de contacto:

- Resultado esperado: No permitir inyección SQL
- Resultado real: Se pudo insertar código para inyección SQL indicando falla en la validación

Pruebas de compatibilidad con navegadores

- Resultado esperado: 100% funcional sitio web en Chrome, Firefox, Safari, Opera y Edge
- Resultado real: En Safari y Chrome no cargan adecuadamente algunos estilos CSS

Pruebas de performance

- Resultado esperado: Tiempo de carga página de inicio < 2 segundos
- Resultado real: Tiempo de carga homepage = 3 segundos

Pruebas sistema y software

Pruebas unitarias código backend: Cobertura actual: 65%

Pruebas integración APIs de terceros

Scaneo de vulnerabilidades de infraestructura

Pruebas de penetración de caja negra a página web

Análisis estático de código fuente

Backup y reportes

Backup de archivos:

- Semanal
- Retención de 1 mes.

Medio:

- Almacenamiento en la Nube a través de Github
- Unidades Flash USB

Backup de logs: Almacenamiento centralizado en servicio de terceros. 5 años de retención en frío.

RAM uso, latencia red, throughput, espacio en disco, etc.

Guía señales y marcas

Comentarios con marcadores en código fuente que indiquen funcionalidad pendiente o bugs conocidos.

Uso de protocolos y puertos no estándar: posibles backdoors o accesos no documentados.

Llamadas a funciones sensible como `exec()`, `system()`, `eval()`: pueden permitir ejecución de comandos.

Desactivación de protecciones con funciones como `set_exception_handler()`: interferencia en manejo de errores.

Uso de `include()` o `require()` a archivos remotos: riesgo de inclusión de código no confiable.

Parámetros en URLs que no se validan ni sanitizan antes de usarse.

Cuestionarios y entrevistas

¿Qué perfil de usuario tiene permisos para dar de alta, baja o modificar moderadores dentro del sistema?

¿Existe algún flujo de trabajo o aprobación requerida para agregar o eliminar un moderador?

¿Cómo se autentican los moderadores al acceder al sistema de gestión de contenidos?

¿De qué forma se establece y modifica el tiempo de las presentaciones por parte de los moderadores?

¿El sistema cuenta con reportes o bitácoras de las actividades realizadas por los moderadores?

Respecto al registro de asistencia de los moderadores a los eventos ¿cómo se realiza este proceso?

¿Existen perfiles personalizados de moderador dependiendo de sus responsabilidades?

¿Qué controles existen alrededor de estas funcionalidades para prevenir accesos no autorizados?

¿Qué tipos de pruebas realizan sobre la aplicación web? ¿Con qué herramientas?

¿Cada cuánto se realizan pruebas de seguridad a la aplicación?

¿Se llevan indicadores o métricas de calidad y seguridad de la aplicación?

Anexos, cuadros y estadísticas

Carpeta comprimida DEXT.

Base de datos incorporada.